

Bunni v2 Audit Summary

Prepared by Cyfrin

Version 2.1

Lead Auditors

Giovanni Di Siena

Draiakoo

Assisting Auditors

Pontifex

June 11, 2025

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 3

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 4

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Bacon Labs on Bunni v2. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.1 dated June 11, 2025, was delivered to Bacon Labs, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Bacon Labs or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 40 days, the Cyfrin team conducted an audit on the Bunni v2 code provided by Bacon Labs. The findings consist of 1 Critical, 1 High, 16 Medium & 7 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Bunni v2
Repository	bunni-v2
Commit	344ec228f5eb...
Audit Timeline	Mar 24th - May 16th, 2025
Methods	Manual Review, Stateful Fuzzing

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	1	1	0
High Risk	1	0	1
Medium Risk	16	14	2
Low Risk	7	5	2
Informational	20	14	6
Gas Optimizations	5	4	1
Total	50	38	12

6 Audit Scope

All files present in the `src` directory of the Bunni repo at commit hash 344ec22 were included in the scope of the audit, except for the following exclusions:

```
src/interfaces
src/lib/SqrtPriceMath.sol
src/lib/OrderHashMemory.sol
src/lib/LiquidityAmounts.sol
src/base/ERC20.sol
src/base/Ownable.sol
```

The following pull requests were also considered as part of an additional follow-up scope during the mitigation review:

- PR #118, which allows Bunni liquidity to be used for rebalances.
- PR #129, along with commit 4f84c95, which updates the hooklet surge fee override.
- PR #130, which implements protocol fee changes.
- PR #131, which reduces bytecode size.
- PR #132, which replaces the referral system with a curator fee.

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

Bunni v2 is a DEX built on Uniswap v4 that aims to maximize liquidity provider profits in all market conditions.

Key features include:

- fully custom accounting based on various liquidity density functions
- shapeshifting liquidity that allows the liquidity profile to morph as on-chain market conditions change
- autonomous rebalancing executed via FloodPlain
- volatility-sensitive dynamic/surge fees
- rehypothecation into ERC-4626 vaults based on target ratios

Among other contracts, it comprises the canonical `BunniHook` and the central `BunniHub`, which handles ERC-6909 claim token accounting for raw balances and vault reserves.

9 Attestation

Cyfrin attests that it performed a security review of the Bunni v2 code provided by Bacon Labs.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2025-06-10-cyfrin-bunni-v2.1.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Bacon Labs has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=5a10fb16ff23a8dbbef3a5fb05d3c578dbc49b6de3485be23497d6fdf535dc84
F=2025-06-10-cyfrin-bunni-v2.1-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.